



WEEKLY CYBERSTER INTERNSHIP REPORT

Week 02: Network Enumeration & Service Vulnerability Discovery

NAME	Saima naz
BATCH	Red Team Batch 2
INSTRUCTOR	Umar Niaz
TARGET	Metasploitable 2
DATE	01/7/2026

EXECUTIVE SUMMARY

This report summarizes the work completed during **Week 02** of the Cyberster Red Team Internship Program. The primary focus of this phase was to perform advanced network enumeration, service fingerprinting, vulnerability discovery, and stealth scanning techniques on authorized laboratory targets. The objective was to strengthen practical skills in identifying open ports, enumerating running services, detecting potential vulnerabilities, and understanding firewall evasion techniques while conducting all activities in a controlled and authorized environment.

To accomplish these objectives, four structured tasks were completed using industry-standard security tools, primarily **Nmap**, along with **Netcat (nc)**, **Telnet**, and **Enum4linux**. The assessment included TCP Connect and SYN Stealth scans, UDP scanning, timing template analysis, service version detection, manual banner grabbing, SMB enumeration, Nmap Scripting Engine (NSE) vulnerability scanning, and firewall evasion techniques such as packet fragmentation, MTU manipulation, decoy scanning, and source port spoofing. The collected results provided valuable insights into the target's network services, software versions, potential security weaknesses, and the effectiveness of various scanning techniques, establishing a strong foundation for future vulnerability assessment and penetration testing activities.

Objective:

To transition from broad reconnaissance to targeted network scanning, identifying open ports, and fingerprinting services while avoiding basic security triggers

Task 01: Advanced Network Scanning with Nmap

- Description: Move beyond basic ping sweeps to conduct deep-dive port scanning.
- Technical Requirements:
 - Perform TCP Connect scans (-sT) and SYN Stealth scans (-sS) and compare the results in terms of speed and visibility.
 - Conduct UDP Scanning (-sU) on the top 100 most common UDP ports (DNS, SNMP, DHCP).
 - Use Timing Templates (-T0 to -T5) to understand how scan speed affects reliability and detection.
- Learning Goal: Understand the mechanics of the TCP 3-way handshake and why Stealth scans are preferred in professional Red Teaming.

Task 1 Part 1:- Perform TCP Connect scans (-sT) and SYN Stealth scans (-sS) and compare the results in terms of speed and visibility

Objective

The objective of this task is to compare TCP Connect Scans and SYN Stealth Scans in terms of scan speed, visibility, and detection while understanding the TCP three-way handshake used to establish network connections.

Tools Used

- Kali Linux
- Nmap
- Metasploitable 2 (Target)

Theory

TCP Three-Way Handshake

TCP establishes a connection using three steps:

Step 1

Client → **SYN**

The client sends a synchronization (SYN) request to the server.

Step 2

Server → **SYN-ACK**

The server acknowledges the request and responds with SYN-ACK.

Step 3

Client → **ACK**

The client sends an ACK packet.

The TCP connection is now established, and data transfer can begin.

Why It Matters for Nmap

TCP Connect Scan (-sT)

- Completes the entire TCP three-way handshake.
- Establishes a full connection.
- Easier for firewalls and IDS to detect.
- Usually recorded in server logs.

SYN Stealth Scan (-sS)

- Sends only the SYN packet.
- Receives SYN-ACK.
- Sends an RST packet instead of ACK.
- Connection remains half-open.
- Faster and less detectable.

- **Commands Used**

- **TCP Connect Scan**

- `nmap -sT -p 1-1000 -oN results_sT.txt 192.168.208.129`



```
$ nmap -sT -p 1-1000 -oN results_sT.txt 192.168.208.129
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-29 02:50 EDT
Nmap scan report for 192.168.208.129 (192.168.208.129)
Host is up (0.0083s latency).
Not shown: 988 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
MAC Address: 00:0C:29:CB:BF:80 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.87 seconds
```

What to Record

1. Open Ports and Services Reported

- A total of **12 open TCP ports** were discovered on the target system.
- **2. Scan Duration**
- The TCP Connect Scan completed successfully in **1.87 seconds**

What to Expect

- The TCP Connect Scan completed the full TCP three-way handshake with each open port on the target. As expected, Nmap identified multiple open services including FTP, SSH, HTTP, SMB, and DNS. Because the scan establishes a complete TCP connection, it generates more network traffic and is more likely to be recorded by the target system's logs or detected by security monitoring tools. The scan successfully identified the available services while completing in **1.87 seconds**.

2) SYN Stealth scan (-sS)

```
sudo nmap -sS -p 1-1000 -oN results_sS.txt 192.168.208.129
```

```
L$ sudo nmap -sS -p 1-1000 -oN results_sS.txt 192.168.208.129
[sudo] password for saimanaz:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-29 02:58 EDT
Nmap scan report for 192.168.208.129 (192.168.208.129)
Host is up (0.00014s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
MAC Address: 00:0C:29:CB:BF:80 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.51 seconds
```

What to Record

1. Open Ports and Services Reported

A total of 12 open TCP ports were identified during the SYN Stealth Scan.

2. Scan Duration

The SYN Stealth Scan completed successfully in 0.51 seconds.

3. Ports Appearing in One Scan but Not the Other

No differences were observed between the TCP Connect Scan (-sT) and the SYN Stealth Scan (-sS). Both scans identified the same 12 open ports and services.

4. Interpretation

The SYN Stealth Scan successfully identified the same open ports as the TCP Connect Scan while completing significantly faster (0.51 seconds compared to 1.87 seconds). Because the scan sends a SYN packet and resets the connection before completing the TCP three-way handshake, it generates less network traffic and is less likely to be detected or logged by the target system. These characteristics make the SYN Stealth Scan the preferred choice for reconnaissance during professional Red Team engagements.

Feature	TCP Connect (-sT)	SYN Stealth (-sS)
Scan Time	1.87 seconds	0.51 seconds
Open Ports Found	12	12
Services Detected	Same	Same
TCP Handshake	Full 3-way handshake	Half-open handshake
Visibility	Higher	Lower
Logging	More likely	Less likely
Detection	Easier to detect	Harder to detect
Preferred For	Basic scanning	Professional Red Team reconnaissance

3) UDP scan (top 100 UDP ports)

Command Used

sudo nmap -sU --top-ports 100 -oN results_udp.txt 192.168.208.129

```
(saimanaz@Saimanaz) [ / week2 ]
$ sudo nmap -sU --top-ports 100 -oN results_udp.txt 192.168.208.129
[sudo] password for saimanaz:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-29 03:16 EDT
Nmap scan report for 192.168.208.129 (192.168.208.129)
Host is up (0.0017s latency).
Not shown: 93 closed udp ports (port-unreach)
PORT      STATE      SERVICE
53/udp    open       domain
68/udp    open|filtered dhcpc
69/udp    open|filtered tftp
111/udp   open       rpcbind
137/udp   open       netbios-ns
138/udp   open|filtered netbios-dgm
2049/udp  open       nfs
MAC Address: 00:0C:29:CB:BF:80 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 105.53 seconds
```

What to Record

1. UDP Ports Returned

UDP Port	State	Service
53/udp	Open	DNS (Domain)
68/udp	Open Filtered	DHCP Client (dhcpc)
69/udp	Open Filtered	TFTP
111/udp	Open	RPCBind
137/udp	Open	NetBIOS Name Service
138/udp	Open Filtered	NetBIOS Datagram Service
2049/udp	Open	NFS

A total of **7 UDP ports** were identified during the scan. Nmap also reported **93 closed UDP ports**.

2. Scan Duration

The UDP scan completed in **105.53 seconds**. Compared to TCP scans, the UDP scan required significantly more time because UDP is a connectionless protocol and often requires retransmissions or timeouts before determining the state of a port.

3. Services Discovered

The following UDP services were discovered:

- **DNS (Port 53)** – Domain Name System service.
- **DHCP Client (Port 68)** – DHCP client service (Open | Filtered).
- **TFTP (Port 69)** – Trivial File Transfer Protocol (Open | Filtered).
- **RPCBind (Port 111)** – Remote Procedure Call service.
- **NetBIOS Name Service (Port 137)** – Network name resolution service.
- **NetBIOS Datagram Service (Port 138)** – Network datagram service (Open | Filtered).
- **NFS (Port 2049)** – Network File System service.

4. Notes

UDP is a connectionless protocol and does not use the TCP three-way handshake. As a result, many UDP services do not respond to probes, causing Nmap to report some ports as **Open | Filtered**. This means the port may be open, or a firewall may be filtering the traffic. UDP scans are generally slower than TCP scans because Nmap must wait for response timeouts before determining the state of each port. In this assessment, the scan took **105.53 seconds**, which is considerably longer than the previous TCP Connect and SYN Stealth scans.

4) Timing templates (-T2 vs -T4)

Commands

```
sudo nmap -sS -T2 -p 1-1000 -oN sS_T2.txt 192.168.208.129
```

```
$ sudo nmap -sS -T2 -p 1-1000 -oN sS_T2.txt 192.168.208.129
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-29 03:26 EDT
Nmap scan report for 192.168.208.129 (192.168.208.129)
Host is up (0.00061s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
MAC Address: 00:0C:29:CB:BF:80 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 401.37 seconds
```

Commands (aggressive)

```
sudo nmap -sS -T4 -p 1-1000 -oN sS_T4.txt 192.168.208.129
```

```
$ sudo nmap -sS -T4 -p 1-1000 -oN sS_T4.txt 192.168.208.129
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-29 03:35 EDT
Nmap scan report for 192.168.208.129 (192.168.208.129)
Host is up (0.00037s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
MAC Address: 00:0C:29:CB:BF:80 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.26 seconds
```

What to Record

1. Duration for Each Run

Timing Template	Scan Duration
-T2 (Polite)	401.37 seconds
-T4 (Aggressive)	0.26 seconds

2. Differences in Ports Reported

No differences were observed between the two scans. Both timing templates identified the same **12 open TCP ports**:

3. Did the Faster Scan Miss Any Ports?

No. The **-T4** scan completed much faster than the **-T2** scan while detecting the same open ports. No ports were missed, and the results were consistent across both scans.

Scan	Time Taken	Open Ports	Observation
-T2 (Polite)	401.37 s	12	Very slow, stealthier, lower network load
-T4 (Aggressive)	0.26 s	12	Very fast, noisier, more likely to trigger alerts

Template	Name	Behavior
-T0	Paranoid	Extremely slow
-T1	Sneaky	Very slow
-T2	Polite	Slow, reduces network load
-T3	Normal	Default timing
-T4	Aggressive	Faster scanning

-T5	Insane	Very fast but less reliable
-----	--------	-----------------------------

Task 02: Service Fingerprinting & Banner Grabbing

Description: Identify the exact versions of services running on open ports to look for known vulnerabilities.

- Technical Requirements:

- Use Nmap's Version Detection (-sV) and Aggressive Scan (-A) flags to identify service details.
- Perform Manual Banner Grabbing using Netcat (nc) or Telnet to verify service headers.
- Use Enum4linux or Samba tools if SMB (Port 445) is found open to list shares and users.

- Learning Goal: Realize that a service version is the primary "key" to finding a specific exploit (CVE).

Part 1 — Service Version Detection with Nmap and Aggressive Scan

Nmap can automatically detect the service name and version running on open ports.

1. **Service Version Detection (-sV)**
2. **Aggressive Scan (-A)**

Step 1 – Service Version Detection

Run:

```
nmap -sV 192.168.208.129
```

or, to save the output:

```
nmap -sV -oN results_sV.txt 192.168.208.129
```

```
$ nmap -sV 192.168.208.129
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-30 01:37 EDT
Nmap scan report for 192.168.208.129 (192.168.208.129)
Host is up (0.00028s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
```

Port	Service	Version
21/tcp	FTP	vsftpd 2.3.4
22/tcp	SSH	OpenSSH 4.7p1 Debian 8ubuntu1 (Protocol 2.0)
23/tcp	Telnet	Linux telnetd
25/tcp	SMTP	Postfix smtpd
53/tcp	DNS	ISC BIND 9.4.2

Analysis

The Version Detection scan successfully identified 23 open TCP services running on the target system. Unlike previous scans that only revealed open ports, the -sV option accurately determined the software implementation and version for each service. Critical services identified include Apache HTTP Server 2.2.8, OpenSSH 4.7p1, MySQL 5.0.51a, PostgreSQL 8.3.x, Samba 3.X-4.X, vsftpd 2.3.4, and UnrealIRCd. Identifying the exact software versions is

essential because known vulnerabilities and CVEs are associated with specific versions rather than simply with port numbers. These results provide the necessary information for conducting vulnerability assessment and selecting appropriate exploits during later stages of a penetration test.

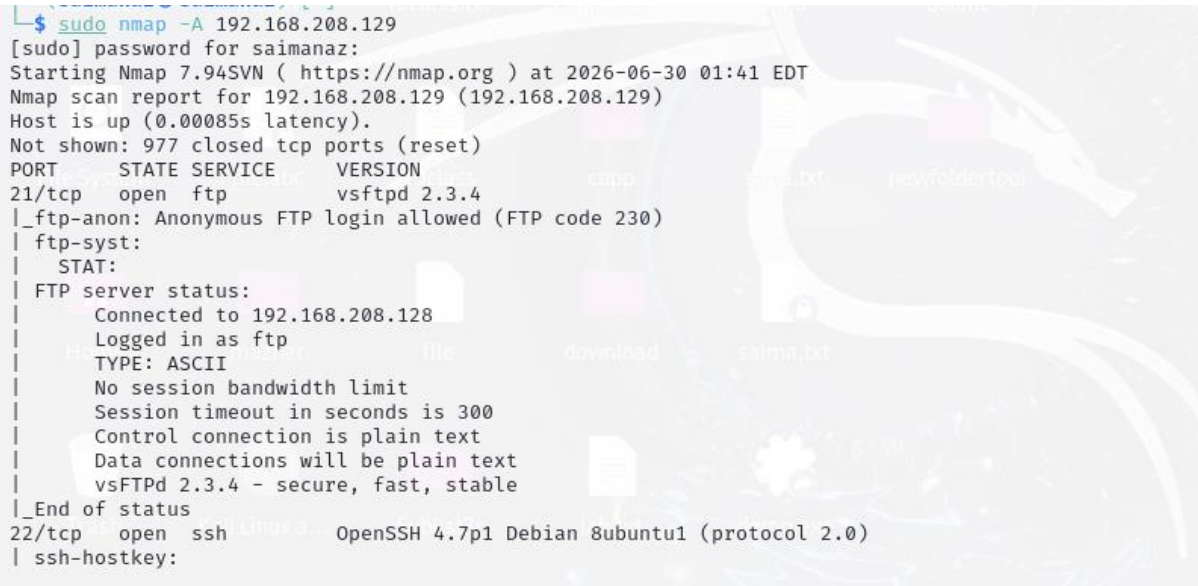
Step 2 – Aggressive Scan

Run:

```
sudo nmap -A 192.168.208.129
```

or:

```
sudo nmap -A -oN results_A.txt 192.168.208.129
```



```
$ sudo nmap -A 192.168.208.129
[sudo] password for saimanaz:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-30 01:41 EDT
Nmap scan report for 192.168.208.129 (192.168.208.129)
Host is up (0.00085s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 192.168.208.128
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   vsFTPD 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
```

```

STAT:
FTP server status:
  Connected to 192.168.208.128
  Logged in as ftp
  TYPE: ASCII
  No session bandwidth limit
  Session timeout in seconds is 300
  Control connection is plain text
  Data connections will be plain text
  vsFTPD 2.3.4 - secure, fast, stable
_End of status
22/tcp open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
  ssh-hostkey:
    1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
    2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp open  telnet      Linux telnetd
25/tcp open  smtp       Postfix smtpd
_ssl-date: 2026-06-30T05:43:10+00:00; +5s from scanner time.
sslv2:
  SSLv2 supported
  ciphers:
    SSL2_RC4_128_EXPORT40_WITH_MD5
    SSL2_RC2_128_CBC_WITH_MD5
    SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
    SSL2_DES_192_EDE3_CBC_WITH_MD5

1 100021 1,3,4 45101/udp nlockmgr
1 100024 1 56982/udp status
1 100024 1 59112/tcp status
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec?
513/tcp open login?
514/tcp open tcpwrapped
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.3.1
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
| mysql-info:
| Protocol: 10
| Version: 5.0.51a-3ubuntu5
| Thread ID: 9
| Capabilities flags: 43564
| Some Capabilities: SupportsTransactions, Speaks41ProtocolNew, SwitchToSSLAfterHandshake, Support41Auth, ConnectWithDatabase, LongColumnNames, SupportsCompression
| Status: Autocommit
| _ Salt: vg%{'0LkZ]G+?:D)@F!l
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX

```

1. Operating System Guess

INFORMATION	RESULT
DEVICE TYPE	General Purpose
OPERATING SYSTEM	Linux 2.6.X
OS DETAILS	Linux 2.6.9 – 2.6.33
NETWORK DISTANCE	1 Hop

2. Additional Service Details

Port	Service	Additional Information
21	FTP	Anonymous FTP login allowed (vsftpd 2.3.4)
22	SSH	SSH host keys (DSA and RSA) detected
25	SMTP	STARTTLS supported, SMTP commands identified
53	DNS	ISC BIND version 9.4.2 confirmed
80	HTTP	Apache HTTP Server 2.2.8, Web title: Metasploitable2 - Linux
445	SMB	Samba 3.0.20-Debian (Workgroup: WORKGROUP)
3306	MySQL	Protocol version and server capabilities detected
5432	PostgreSQL	SSL certificate information detected
5900	VNC	Protocol Version 3.3
6667	IRC	UnrealIRCd server information identified
8180	Apache Tomcat	Apache Tomcat 5.5 detected

3. Extra Script Results

- Anonymous FTP login is enabled.
- Apache web server title identified as "**Metasploitable2 - Linux.**"
- DNS server version detected as **ISC BIND 9.4.2.**
- SMTP supports STARTTLS and several mail commands.
- SMB enumeration revealed the hostname **metasploitable.localdomain.**
- SMB message signing is disabled.
- MySQL server capabilities and protocol information were successfully retrieved.
- IRC server details and version information were identified.
- Traceroute showed the target is **1 network hop** away.

Part 2 — Manual Banner Grabbing

Method 1 — Using Netcat

Command Used

```
nc 192.168.208.129 21
```

Commands Entered

USER anonymous

PASS anonymous

SYST

FEAT

QUIT

A screenshot of a terminal window on a Kali Linux system. The terminal shows a Netcat session where the user connects to 192.168.208.129 on port 21. The output shows the server is vsFTPD 2.3.4. The user enters 'USER anonymous' and 'PASS anonymous', and the server responds with '230 Login successful.'. The user then enters 'SYST' and receives '215 UNIX Type: L8'. The user enters 'FEAT' and receives a list of features: '211-Features: EPRT, EPSV, MDTM, PASV, REST STREAM, SIZE, TVFS, UTF8'. The user enters 'QUIT' and receives '221 Goodbye.'. The terminal background shows a Kali Linux desktop environment with various icons and a file manager window open.

1. Connect to the FTP server

```
nc 192.168.208.129 21
```

- nc = Netcat (a networking tool)
- 192.168.208.129 = Target IP

- 21 = FTP port

The server immediately replies:

220 (vsFTPD 2.3.4)

This is called the **banner**.

Meaning:

- **220** = FTP service is ready.
- **vsFTPD** = The FTP server software.
- **2.3.4** = The software version.

This is the main purpose of **banner grabbing**—to identify the software and its version.

2. Username

USER anonymous

You tell the FTP server:

"I want to log in as the anonymous user."

The server replies:

331 Please specify the password.

Meaning:

"Okay, now send the password."

3. Password

PASS anonymous

You provide a password (for anonymous FTP, it's commonly anonymous).

The server replies:

230 Login successful.

Meaning:

"Login successful."

This confirms that anonymous FTP access is enabled.

4. System Information

SYST

This asks:

"What operating system are you running?"

The server replies:

215 UNIX Type: L8

Meaning:

- Operating System: **UNIX/Linux**
- File transfer type: **L8 (8-bit binary)**

5. Features

FEAT

This asks:

"What FTP features do you support?"

The server replies:

211-Features:

EPRT

EPSV

MDTM

PASV

REST STREAM

SIZE

TVFS

UTF8

211 End

This is simply a list of capabilities supported by the FTP server.

6. Quit

QUIT

This politely closes the FTP session.

The server replies:

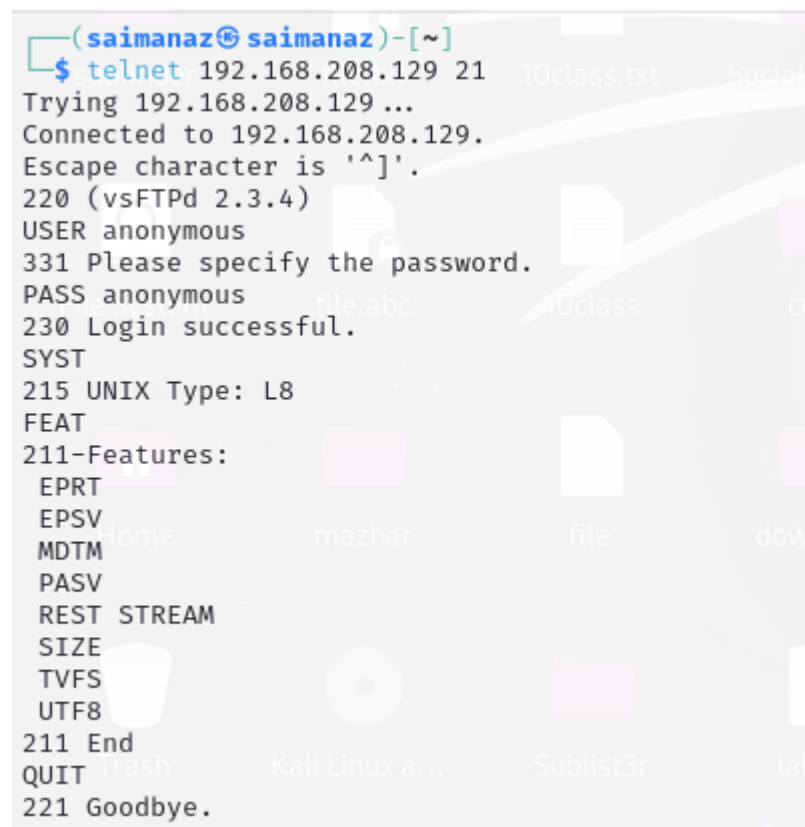
221 Goodbye.

Meaning:

"The connection has been closed."

Method 2 — Using Telnet

telnet 192.168.208.129 21



```
(saimanaz@~)-[~]
$ telnet 192.168.208.129 21
Trying 192.168.208.129 ...
Connected to 192.168.208.129.
Escape character is '^]'.
220 (vsFTPd 2.3.4)
USER anonymous
331 Please specify the password.
PASS anonymous
230 Login successful.
SYST
215 UNIX Type: L8
FEAT
211-Features:
  EPRT
  EPSV
  MDTM
  PASV
  REST STREAM
  SIZE
  TVFS
  UTF8
211 End
QUIT
221 Goodbye.
```

Part 3 — SMB Enumeration (If Port 445 Is Open)

command

```
enum4linux -a 192.168.208.129
```

What does enum4linux do?

enum4linux is a Linux tool used to gather information from SMB (Server Message Block) or **Samba** services. It helps security professionals identify information that is publicly accessible or accessible without exploiting the target.

Purpose of the Command

The purpose of this command is to gather information from the SMB service, including:

- Shared folders (SMB shares) available on the target.
- User accounts configured on the system.
- Groups and their members.
- Computer name and workgroup/domain.
- Operating system information (if available).
- Other SMB-related configuration details.
-

Why is this important?

- During the reconnaissance phase of a penetration test, knowing the available shares, user accounts, and system information helps security professionals understand the target environment and identify potential security weaknesses. This information is collected without exploiting the system and forms the basis for further authorized security assessment.

```

└─$ enum4linux -a 192.168.208.129
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Jun 30 02:56:17 2015

===== ( Target Information ) =====
Target ..... 192.168.208.129
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.208.129 ) =====
[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 192.168.208.129 ) =====
Looking up status of 192.168.208.129
METASPLOITABLE <00> - B <ACTIVE> Workstation Service
METASPLOITABLE <03> - B <ACTIVE> Messenger Service
METASPLOITABLE <20> - B <ACTIVE> File Server Service
.. __MSBROWSE__.. <01> - <GROUP> B <ACTIVE> Master Browser

```

Task 03: Leveraging Nmap Scripting Engine (NSE)

Example 1 — HTTP Enumeration

nmap -p 80 --script http-enum 192.168.208.129

```

└─$ nmap -p 80 --script http-enum 192.168.208.129
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-30 03:03 EDT
Nmap scan report for 192.168.208.129 (192.168.208.129)
Host is up (0.0021s latency).

PORT      STATE SERVICE
80/tcp    open  http
| http-enum:
|   /tikiwiki/: Tikiwiki
|   /test/: Test page
|   /phpinfo.php: Possible information file
|   /phpMyAdmin/: phpMyAdmin
|   /doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
|   /icons/: Potentially interesting folder w/ directory listing
|_  /index/: Potentially interesting folder
MAC Address: 00:0C:29:CB:BF:80 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 3.09 seconds

```

Purpose

The http-enum NSE script is used to discover common web directories, files, login pages, and administrative interfaces on a web server. This helps identify publicly accessible resources that may require further security assessment.

What to Record

Resource Found	Description
/tikiwiki/	TikiWiki web application directory.
/test/	Test page that may be used for development or debugging.
/phpinfo.php	PHP configuration page that may reveal sensitive server information.
/phpMyAdmin/	phpMyAdmin web interface used to manage MySQL databases.
/doc/	Documentation directory with directory listing enabled.
/icons/	Icons directory with directory listing enabled.
/index/	Directory detected as potentially interesting.

Analysis

The http-enum script successfully discovered several publicly accessible web resources on the target server. Notable findings include the phpMyAdmin interface, a PHP information page (phpinfo.php), and the TikiWiki application directory. The scan also identified directories such as /doc/ and /icons/ where directory listing appears to be enabled. These resources may expose configuration details, documentation, or administrative interfaces that should be reviewed during an authorized security assessment. The results demonstrate how the Nmap Scripting Engine (NSE) can automate web reconnaissance and identify resources that might not be immediately visible from the main website.

Discovery scripts

```
nmap --script discovery 192.168.208.129
```

```

$ nmap --script discovery 192.168.208.129
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-30 03:12 EDT
Pre-scan script results:
| broadcast-ping:
|   IP: 192.168.208.2  MAC: 00:50:56:f5:a3:6f
|_ Use --script-args=newtargets to add the results as targets
| targets-ipv6-multicast-mld:
|   IP: fe80::e0c:3bf6:6aec:4dfc  MAC: 00:50:56:c0:00:08  IFACE: eth0
|
|_ Use --script-args=newtargets to add the results as targets
| ipv6-multicast-mld-list:
|   fe80::e0c:3bf6:6aec:4dfc:
|     device: eth0
|     mac: 00:50:56:c0:00:08
|     multicast_ips:
|       ff02::1:ff67:f4b1      (Solicited-Node Address)
|       ff02::1:3              (Link-local Multicast Name Resolution)
|       ff02::1:3              (Link-local Multicast Name Resolution)
|       ff02::1:3              (Link-local Multicast Name Resolution)
|       ff02::1:3              (Link-local Multicast Name Resolution)
|       ff02::1:3              (Link-local Multicast Name Resolution)
|       ff02::1:ff67:f4b1      (Solicited-Node Address)

```

Purpose

The Discovery category of the Nmap Scripting Engine (NSE) is used to collect network information and identify hosts, multicast services, and other discovery-related details without performing intrusive actions.

Observations

- Broadcast ping detected an active device on the local network.
- IPv6 multicast discovery identified IPv6-enabled hosts and multicast addresses.
- IGMP discovery identified multicast services, including:
 - mDNS
 - Link-Local Multicast Name Resolution (LLMNR)
 - SSDP
- Robtex-based discovery scripts were unavailable because the external API is temporarily disabled.
- No additional service details or HTTP headers were returned for the target host.

Analysis

The Discovery scripts gathered information about the surrounding network environment rather than the target system itself. They identified active network devices and multicast services but did not reveal additional information about the target host's services. These scripts are useful for network reconnaissance and identifying devices before conducting more detailed service enumeration.

Safe scripts

`nmap --script safe 192.168.208.129`

```
$ nmap --script safe 192.168.208.129
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-30 03:16 EDT
Pre-scan script results:
| broadcast-igmp-discovery:
|   192.168.208.1
|     Interface: eth0
|     Version: 2
|     Group: 224.0.0.252
|     Description: Link-local Multicast Name Resolution (rfc4795)
|   192.168.208.1
|     Interface: eth0
|     Version: 2
|     Group: 239.255.255.250
|     Description: Organization-Local Scope (rfc2365)
|_ Use the newtargets script-arg to add the results as targets
| broadcast-listener:
|   ether
|     EIGRP Update
|
```

Purpose

The **Safe** category of the Nmap Scripting Engine (NSE) executes non-intrusive scripts to gather information about the network and target system without affecting normal operations.

Findings

Information	Result
Broadcast Ping	Detected an active host at 192.168.208.2
DHCP Discovery	DHCP server identified at 192.168.208.254
Offered IP Address	192.168.208.132
Subnet Mask	255.255.255.0
Default Gateway	192.168.208.2
DNS Server	192.168.208.2
Domain Name	localdomain
Broadcast Address	192.168.208.255
NetBIOS Name Server	192.168.208.2
IGMP Discovery	Detected LLMNR and SSDP multicast groups
Robtex Scripts	Temporarily unavailable due to API changes

Analysis

The Safe NSE scripts collected non-intrusive network information, including DHCP configuration, DNS server details, gateway information, and multicast services. These scripts focused on network reconnaissance and did not identify additional HTTP headers, SSL certificates, or service-specific information for the target. Safe scripts are useful because they gather reconnaissance data without performing intrusive or potentially disruptive actions.

Example 2 — SSL Certificate Information

command:

```
nmap -p 443 --script ssl-cert 192.168.208.129
```

```
L$ nmap -p 443 --script ssl-cert 192.168.208.129
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-01 01:14 EDT
Nmap scan report for 192.168.208.129 (192.168.208.129)
Host is up (0.00035s latency).

PORT      STATE SERVICE
443/tcp    closed https
MAC Address: 00:0C:29:CB:BF:80 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.53 seconds
```

Observation

The ssl-cert NSE script was executed on port **443** to retrieve SSL/TLS certificate information. However, the target's HTTPS port was closed, so no SSL certificate was available for analysis. Therefore, certificate details such as the subject, issuer, public key type, and validity period could not be obtained. there is no HTTPS service running, so the ssl-cert script has no certificate to retrieve.

❓ 443 (HTTPS)

❓ 465 (SMTPS)

❓ 993 (IMAPS)

❓ 995 (POP3S)

❓ 8443 (HTTPS alternate)

The ssl-cert NSE script can retrieve SSL/TLS certificate information from any service that uses SSL/TLS encryption. While HTTPS commonly uses port 443, other services such as SMTPS (465), IMAPS (993), POP3S (995), and HTTPS Alternate (8443) may also provide SSL certificates. If any of these ports are open and configured with SSL/TLS, the ssl-cert script can be executed against that port to obtain certificate details.

Task 3 Part 2

Running Vulnerability Scripts

Command

nmap --script vuln 192.168.208.129

```
└─$ nmap --script vuln 192.168.208.129
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-01 01:24 EDT
Nmap scan report for 192.168.208.129 (192.168.208.129)
Host is up (0.00044s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDs:  BID:48539  CVE:CVE-2011-2523
|       vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|       Disclosure date: 2011-07-03
|       Exploit results:
|         Shell command: id
|         Results: uid=0(root) gid=0(root)
|       References:
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|         https://www.securityfocus.com/bid/48539
|         https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|         http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|_
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
```

Purpose

The vuln category of the Nmap Scripting Engine (NSE) automates vulnerability detection by checking services against known security weaknesses. The scripts help identify publicly documented vulnerabilities and map them to their corresponding CVE (Common Vulnerabilities and Exposures) identifiers.

Vulnerabilities Identified

Port	Service	Vulnerability	CVE ID	Status
21	FTP (vsFTPD 2.3.4)	vsFTPD 2.3.4 Backdoor	CVE-2011-2523	Vulnerable
25	SMTP (TLS)	Logjam Attack (Weak Diffie-Hellman Parameters)	CVE-2015-4000	Vulnerable

Port	Service	Vulnerability	CVE ID	Status
25	SMTP (TLS)	Anonymous Diffie-Hellman Key Exchange	No CVE Assigned	Vulnerable

CVE Mapping

CVE-2011-2523

- **Affected Service:** vsFTPD 2.3.4 (FTP)
- **Description:** A backdoored version of vsFTPD 2.3.4 allows unauthorized remote access if the compromised software is installed.
- **Detected By:** ftp-vsftpd-backdoor NSE script.

CVE-2015-4000 (Logjam)

- **Affected Service:** SMTP with TLS
- **Description:** The server supports weak Diffie-Hellman parameters, allowing a potential downgrade attack that weakens encrypted communications.
- **Detected By:** ssl-dh-params NSE script.

Task 03 – Part 3

Mapping NSE Output to CVE IDs

Commands:

```
sudo nmap -sV --script vuln 192.168.208.129
```

```

L$ sudo nmap -sV --script vuln 192.168.208.129
[sudo] password for saimanaz:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-01 01:57 EDT
Nmap scan report for 192.168.208.129 (192.168.208.129)
Host is up (0.00093s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDs:  BID:48539  CVE:CVE-2011-2523
|       vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|       Disclosure date: 2011-07-03
|       Exploit results:
|         Shell command: id
|         Results: uid=0(root) gid=0(root)
|       References:
|         http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523

```

04: Stealth & Firewall Evasion Techniques

Task 04 – Part 1: Packet Fragmentation (-f)

Command:

```
sudo nmap -sS -f 192.168.208.129
```

purpose:

Normally, Nmap sends each probe as one complete IP packet. The -f option fragments the packet into smaller pieces. This technique may evade simple packet filters or IDS devices that do not correctly reassemble fragmented packets.

```

$ sudo nmap -sS -f 192.168.208.129
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-01 01:24 EDT
Nmap scan report for 192.168.208.129 (192.168.208.129)
Host is up (0.00044s latency).
Not shown: 977 closed tcp ports (reset)
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-01 01:47 EDT
Stats: 0:00:01 elapsed; 0 hosts completed (0 up), 1 undergoing ARP Ping Scan
ARP Ping Scan Timing: About 100.00% done; ETC: 01:47 (0:00:00 remaining)
Nmap scan report for 192.168.208.129 (192.168.208.129)
Host is up (0.00067s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      CVE:CVE-2011-2523
21/tcp    open  ftp          version 2.3.4 backdoor, this was reported on 2011-07-04.
22/tcp    open  ssh          date: 2011-07-03
23/tcp    open  telnet
25/tcp    open  smtp
33/tcp    open  domain=0(root) gid=0(root)
30/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
12/tcp    open  exec
13/tcp    open  login
14/tcp    open  shell
1099/tcp  open  rmiregistry

```

Task 04 – Part 2: MTU Manipulation

Command:

```
sudo nmap -sS --mtu 24 192.168.208.129
```

purpose:

Instead of using the default fragment size, you specify a custom MTU (Maximum Transmission Unit). This changes how Nmap fragments packets.

```

└─$ sudo nmap -sS --mtu 24 192.168.208.129
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-01 01:51 EDT
Nmap scan report for 192.168.208.129 (192.168.208.129)
Host is up (0.0010s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp

```

Task 04 – Part 3: Decoy Scan (-D)

Purpose

A decoy scan mixes your IP address with several fake IP addresses, making it harder to determine which host initiated the scan.

Command

```
sudo nmap -sS -D RND:5 192.168.208.129
```

```

└─$ sudo nmap -sS -D RND:5 192.168.208.129
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-01 01:54 EDT
Nmap scan report for 192.168.208.129 (192.168.208.129)
Host is up (0.000088s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql

```

Task 04 – Part 4: Source Port Spoofing

Purpose

Some firewalls trust traffic coming from specific ports such as **53 (DNS)**. This option changes the source port of your scan packets.

Command

`sudo nmap -sS --source-port 53 192.168.208.129`

```
└─$ sudo nmap -sS --source-port 53 192.168.208.129
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-01 01:55 EDT
Nmap scan report for 192.168.208.129 (192.168.208.129)
Host is up (0.00056s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
```

Technique	Command	Purpose	Expected Result
Packet Fragmentation	-f	Break packets into smaller fragments	Same ports detected; fragmented packets
MTU Manipulation	--mtu 24	Control packet fragment size	Same ports; different packet size

Technique	Command	Purpose	Expected Result
Decoy Scan	-D RND:5	Hide the scanner among fake IP addresses	Same ports; target sees multiple source IPs
Source Port Spoofing	--source-port 53	Use a trusted source port	Same ports; may bypass simple firewall rules